Semana 06 — Auditor con veredicto y hardening reproducible

Grupo 4 · rol Azul · ejemplo de trabajo

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	06 de 10
Fase	3 — Defensa y hardening
Grupo	4
Rol	Azul
Entrega	GitHub, carpeta semana_06/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Tu rol en la práctica

Parte de su propia captura cruda y aplica el control equivalente: configuración, parche o regla de red. Repite el ataque para demostrar que falla y documenta el antes y el después.

- Leer su propia evidencia cruda y elegir el control que corta el ataque en el punto más barato.
- Aplicar el control y repetir el ataque para demostrar que ya no funciona.
- Documentar el antes y el después con los mismos comandos y la diferencia medida.

2 Qué aporta este rol al entregable

La mitigación aplicada, el comando de verificación y la comparación de resultados.

3 Ejemplo paso a paso

El rol Azul escribe el auditor que decide, aplica los cambios y demuestra con la misma herramienta que el estado cambio. El entregable es la comparacion, no la configuracion sola.

3.1 Escribir el auditor con veredicto por control

El auditor emite una linea por control con estado y veredicto. Un control no medible devuelve "no_verificado", no un aprobado por defecto.

```
mkdir -p semana_06/evidencia
cat > semana_06/auditor.py <<'PY'
import subprocess

def sshd(clave):
    salida = subprocess.run(['sshd', '-T'], capture_output=True, text=
        True)
    for linea in salida.stdout.splitlines():
        if linea.startswith(clave):
            return linea.split()[1]
    return 'no_verificado'

controles = {
    'permitrootlogin': sshd('permitrootlogin'),
    'passwordauthentication': sshd('passwordauthentication'),
}
for nombre, valor in controles.items():
    if valor == 'no_verificado':
        veredicto = 'no_verificado'
    else:
        veredicto = 'ok' if valor == 'no' else 'fallo'
    print(nombre, valor, veredicto)
PY
python3 semana_06/auditor.py | tee semana_06/evidencia/veredictos_antes
    .txt
```

3.2 Aplicar el hardening por lotes con vuelta atras

Se copia la configuracion antes de tocarla y se recarga solo lo necesario. Si un servicio no vuelve a arrancar, se restaura la copia.

```
sudo cp /etc/ssh/sshd_config semana_06/evidencia/sshd_config.orig
sudo sed -i -E 's/^#?PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/
    sshd_config
sudo sshd -t && sudo systemctl reload ssh 2>/dev/null || sudo kill -HUP
     1
sudo ufw default deny incoming
sudo ufw allow 2222/tcp
sudo ufw --force enable
```

```
python3 semana_06/auditor.py | tee semana_06/evidencia/
    veredictos_despues.txt
```

3.3 Comparar y justificar excepciones

Se comparan los veredictos y se justifica cada control que sigue en fallo. La excepcion se documenta con su motivo y su fecha de revision.

3.4 Verificar que el sistema sigue operativo

Un hardening que deja el sistema inaccesible no es un hardening. Se comprueba el acceso permitido y el servicio que el grupo necesita.

```
ss -tulpn | tee semana_06/evidencia/puertos_final.txt
curl -s -o /dev/null -w '%{http_code}\n' http://127.0.0.1:8081/ \
  | tee semana_06/evidencia/http_final.txt
```

3.5 Control, antes, cambio y verificacion

Control, antes, cambio y verificacion

Control	Antes	Cambio	Despues	Verificacion
Root por SSH	Si	PermitRootLogin no	No	sshd -T
Contrasena SSH	Si	PasswordAuthentication no	No	sshd -T
Filtrado	Inactivo	Deny por defecto y allow 2222	Activo	ufw status
SUID	Conteo base	Sin cambios	Igual	find -perm -4000
Puertos	Conteo base	Solo los del alcance	Reducido	ss -tulpn

La columna de verificacion cita la salida del auditor que soporta el veredicto.

4 Qué guardar en el repositorio

Se entrega el auditor con veredicto, los veredictos antes y despues, los comandos de hardening y la justificacion de cada excepcion.

```
semana_06/
|-- informe.md
|-- auditor.py
```

```
|-- auditor.sh
|-- evidencia/
|   |-- veredictos_antes.txt
|   |-- veredictos_despues.txt
|   |-- puertos_final.txt
|   `-- http_final.txt
`-- README.md
```

- El auditor devuelve no_verificado cuando no puede medir.
- Los veredictos de antes y despues salen del mismo script.
- Cada excepcion tiene motivo y fecha de revision.
- El sistema sigue operativo despues del hardening.

5 Cómo se corrige

Criterio	Peso
Doce controles documentados y verificables	2,0
Auditor funcional con veredicto por control	2,0
Política de filtrado correcta y sistema operativo	2,5
Alertas de Suricata clasificadas y regla propuesta	2,5
Antes/después comparables y justificación de excepciones	1,0
Total	**10,0**

- Un control no medible no se escribe como aprobado.
- {'Recargar SSH en la sesion activa puede expulsar al estudiante': 'se usa consola local.'}

Recuerda

El trabajo es independiente: cada grupo usa su propio repositorio y su propio laboratorio, y la comparación de resultados es en clase. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.